Bricked and Abandoned

Keeping the IoT from becoming an Internet of Trash

Speakers…

Cory Doctorow
Editor, Pluralistic
Special Advisor, EFF

Tarah Wheeler
CEO, Red Queen Dynamics

Chris Wysopal
CTO, Veracode

Dennis Giese
Dontvacuum.me

Paul Roberts, Moderator
President, SRFF
Publisher, Security Ledger

Secure
Resilient
Future
Foundation

Agenda…

- 17:00 – 17:05 Introductions
- 17:05 – 17:30 Understanding our EOL problem
  - Paul – Why this panel? The coming epidemic of abandonware
  - Cory – Enshittification explained
  - Chris – Appsec has a firmware problem
  - Dennis – A terrible state of smart device security, resilience
  - Tarah – Learning from other industries
- 17:30 – 17:40 Fixing the future –addressing EOL risk
- 17:40 – 17:45 How you can help

Epidemic of EOL…

- 29 billion IoT devices projected by 2030 (vs. ~ 15 billion in 2020)
- Divergence between useful life of hardware (decades) and software support (years)
- Currently no laws (in the U.S.) that mandate periods of support
  - End of Life decisions driven by bottom line considerations solely:
    - Age of product
    - Cost of maintenance/upkeep
  - Decisions not informed by:
    - Useful life of hardware
    - Cost of replacement for customer
    - Security risks of unsupported devices

Secure
Resilient
Future
Foundation

Exhibit 1: Spotify Car Thing (2024)

- Portable streaming device for non-smart vehicles
- February 2022: released to the public
- July 2022: Spotify ceases production, cuts price
- May 2024: announces all purchased Car Things will be bricked on December 9th
  - No options to trade in or get a refund
  - No way to re-purpose device
  - Customers told to “follow local electronic waste guidelines” to dispose of Car Things.
- Following customer push back/media attention, offers to buy back Car Thing devices at discounted price.

Secure Resilient Future Foundation

Exhibit 2: Belkin Wemo NetCam (2020)

- Popular Internet connected home surveillance camera

- April 2020: Belkin announces End of Life for three popular WeMo Netcam devices in service for 7+ years. <u>Effective date: May 2020.</u>

- Also announced termination of iSecurity+ cloud video service that enables remote monitoring and management.

- At height of pandemic: home owners using NetCam's to monitor remote properties, family members faced need to venture out and replace hardware.

Secure Resilient Future Foundation

Exhibit 3: K-12 Chromebooks:

- Google Chromebooks sold to K-12 an example:
  - Pandemic spurred massive investments in Chromebooks to enable 1:1 student/computer for 48 million K-12 students
  - Expiration dates based on device certification, not purchase dates
  - Under pressure, Google increased support from 4 to 10 years
  - Estimated savings for districts: > $1.8 billion

MENU | WATCH: GLOBE TODAY | METRO | SPORTS | BUSINESS | POLITICS | OPINION | HEALTH | NEW HAMPSHIRE | RHODE ISLAND | CC

Protestors say Google's Chromebooks stop working too soon

By Hiawatha Bray Globe Staff, Updated April 19, 2023, 11:50 a.m.

Monse shares her experience repairing Chromebooks with her high school in front of Google Cambridge. From left to right: Lucas Rockett Gutterman, US PIRG Education Fund; Monse Genao, senior at Worcester Technical High School; David Webb, Hamilton Computer Repairs COURTESY OF US PIRG

Secure Resilient Future Foundation

SOHO Routers: canaries in the coalmine?

"Our analysis indicates that the operators behind (the Moon) botnet were enrolling the compromised end of life (EoL) devices into an established residential proxy service called Faceless ...that has become an integral tool for cybercriminals in obfuscating their activity."

--Lumen Black Lotus Labs, March 26, 2024

Secure Resilient Future Foundation

Low value devices, high stakes

The operation was conducted with great stealth, sometimes flowing through home routers and other common internet-connected consumer devices, to make the intrusion harder to track…

Home routers are particularly vulnerable, especially older models that have not had updated software and protections.

The New York Times

Chinese Malware Hits Systems on Guam. Is Taiwan the Real Target?

The code, which Microsoft said was installed by a Chinese government hacking group, set off alarms because Guam would be a centerpiece of any U.S. military response to a move against Taiwan.

Share full article

The Great Hall of the People in Beijing. Telecommunications networks are key targets for hackers, and the system in Guam is particularly important to China. Thibault Camus/Associated Press

Secure Resilient Future Foundation

Cory Doctorow

Publisher: Pluralistic
Special Advisor: EFF

Chris Wysopal

CTO, Veracode

Board Member: Secure Resilient Future Foundation (SRFF)

Tarah Wheeler

CEO, Red Queen Dynamics

Senior Fellow for Global Cyber Policy, Council on Foreign Relations

Board Member, SRFF & EFF

Facebook Hearing
Capitol Hill
3:22 PM ET
"SENATOR, WE RUN ADS"
BREAKING NEWS
FACEBOOK CEO: "SLOW IN RECOGNIZING" RUSSIA MEDDLING THREAT
LIVE
CNN
DOW ▲ 463.26
WILL "SIGNIFICANTLY LOWER" ITS 25% TARIFF ON VEHICLE IMPORTS THIS YE
NEWSROOM


MR SNIDER

Dennis Giese

Independent security researcher

Dontvacuum.me

Brick it? Why not?

- A lack of OEM incentives or disincentives for EOL decisions creates a vacuum
  - Cost of disposal borne entirely by consumer/community/planet
  - Abandoning maintenance, repair, upkeep to encourage replacement comes at zero cost to OEM
- Device owners and others (ISPs) also divested from issue of device security/resilience (until they aren't)
  - Lack of information at purchase time (labeling, etc.)

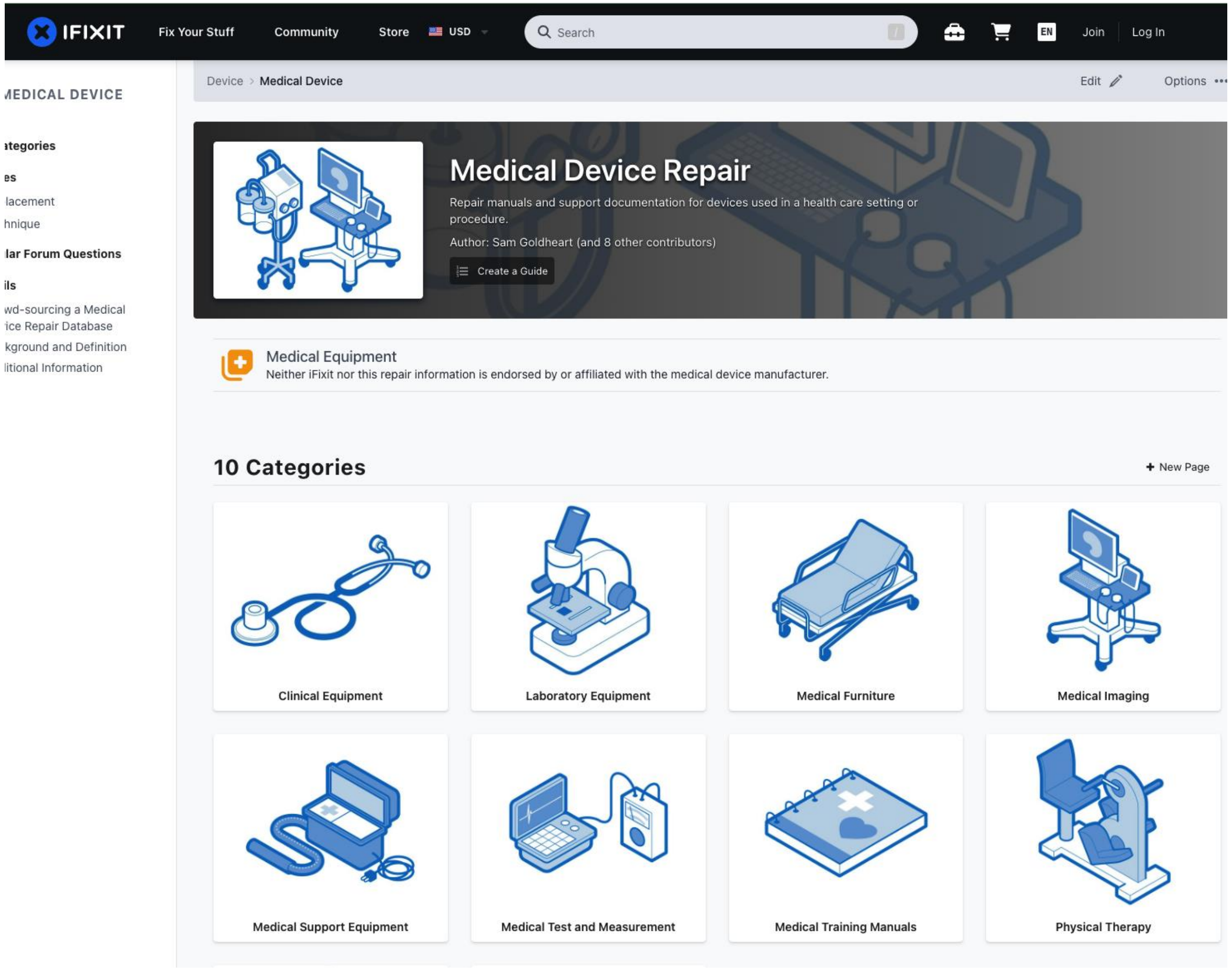
Secure
Resilient
Future
Foundation

Are There Fixes?

- FFS….of course!
- Focus on transparency & resilience
  - SBOM, etc.
  - Data, tools, parts for maintenance and repair (#righttorepair)
  - Source code escrow?
  - Open source?
  - Unlock boot loaders?
- Policy reforms:
  - DMCA reform – fair use exemptions
  - Ban parts pairing
  - Require support for third party parts/software
  - You can fix (and flash) what you own

Examples:

- Encouraging resilient device ecosystems?
  - How to get OEMs to manage updates at scale and over the long term?
- A regulated "graceful default" for manufacturers?
  - Puts guardrails on EOL decisions that emphasize continuity
- Open source it?
  - Pebble smart watch → Rebble.io community supported smart watch
- Collective solutions
  - iFixit taps "the commons" to create medical device repair hub
  - Counters restrictive policies by medical device makers that limit access to service manuals, parts and information



Secure
Resilient
Future
Foundation

Join Us! | Donate!

Sign up for news updates.
Join our Signal group.
Get involved!

Make a donation in any amount to help make change happen!